

Charte sécurité et plan d'action

Renseignements : voir `renseignements.md`.

Mesures techniques et organisationnelles mises en œuvre par Xwégán pour garantir la sécurité des données à caractère personnel, conformément aux articles 424 à 427 du Code du numérique du Bénin.

1. Gestion des accès

- Authentification obligatoire (mot de passe haché, gestion des sessions) pour tous les accès à

la plateforme.

- Principe du moindre privilège : chaque utilisateur ne voit que les données de son propre parc

(propriétaire) ou de son propre logement (locataire).

- Application de la RLS (Row Level Security) au niveau de la base de données : toute lecture ou

écriture est cloisonnée par propriétaire.

- Clé de service réservée au serveur, jamais exposée côté navigateur.

2. Sécurité des données

- Chiffrement des données en transit (HTTPS/TLS).

- Hachage sécurisé des mots de passe (aucun mot de passe en clair).
- Stockage des photos et pièces dans un stockage sécurisé avec accès restreint.
- Sauvegardes régulières de la base de données.
- Journalisation des accès (piste d'audit).

3. Protection technique du service

- Mises à jour régulières des dépendances et correctifs de sécurité.
- Protection contre les accès non autorisés (contrôles serveur, validation des entrées,

protection contre les injections).

- Supervision des erreurs et des anomalies d'accès.
- Environnement de développement séparé de l'environnement de production.

4. Organisation interne

- Engagement de confidentialité signé par toute personne en charge du traitement des données

(voir `01-engagement-confidentialite.md`).

- Sensibilisation et formation des personnes en charge au régime de protection des données

personnelles du Bénin.

- Désignation d'un contact protection des données : dpo@xwegan.com.

5. Gestion des incidents de violation de données

- Procédure : détection, qualification, endiguement, remédiation.
- Notification sans délai à l'APDP de toute violation susceptible d'engendrer un risque pour

les droits et libertés des personnes concernées (article 427).

- Information des personnes concernées dans les meilleurs délais lorsque la violation présente

un risque élevé.

6. Sous-traitants et transferts

- **Supabase** est l'unique sous-traitant (hébergement de la base, du stockage des photos et de

l'authentification). Sa région de serveur est **l'Irlande (Europe)**, c'est-à-dire hors du Bénin : ce transfert est déclaré et encadré dans le présent dossier.

- Toute relation avec un sous-traitant est encadrée par un contrat imposant des garanties de

sécurité et de confidentialité (DPA Supabase) et par une preuve de conformité (SOC 2 / ISO 27001) à joindre au dossier.

- Le transfert de données hors du Bénin est réalisé conformément aux articles 391 et 392 du

Code du numérique (garanties appropriées, clauses contractuelles types de l'APDP ou autorisation préalable), à mentionner dans le formulaire unique.

7. Plan d'action

Action	Responsable	Échéance
Finaliser le dossier APDP (formulaire + pièces)	_____	_____
Faire signer les engagements de confidentialité	_____	_____
Suivre la formation APDP par un formateur agréé	_____	_____
Mettre en place le modèle de consentement (case à cocher)	Réalisé — implémenté dans l'app	15 août 2026
Passer en revue les contrats sous-traitants (hébergeur)	_____	_____
Déposer le dossier et conserver le récépissé	_____	_____

